

PaySafe India

THIRD-PARTY RISK MANAGEMENT FRAMEWORK

Vendor Classification, Risk Scoring Methodology, Due Diligence, Assessment, Monitoring, and Contractual Controls for Third-Party Relationships

Document Title	PaySafe India — TPRM Framework (Third-Party Risk Management)
Framework Reference	PSI-TPRM-2026-01
Subject Organization	PaySafe India (Digital Payments, UPI, BNPL Lending & Card Processing)
Scope	All third-party vendors with system, data, or infrastructure access supporting PaySafe India's payment, KYC, fraud, and communication operations
Effective Date	22 July 2026
Document Classification	Internal — Confidential
Version	v1.0 — Final
Framework Owner	Third-Party / Vendor Risk Manager, in coordination with Head of Compliance and CISO
Approved By	Chief Information Security Officer (CISO); Head of Compliance
Related Deliverables	ISO/IEC 27001:2022 Gap Analysis (v1.0); Risk Register (v1.0); Internal Audit Report — ISMS Control Effectiveness (PSI-IA-2026-04)

Table of Contents

<u>1. Risk Appetite & Tolerance Statement</u>	3
<u>1.1 Statement</u>	3
<u>1.2 Appetite by Band and Required Sign-Off</u>	3
<u>2. Risk Assessment Methodology</u>	3
<u>2.1 Scale Definitions</u>	3
<u>2.2 The Matrix</u>	4
<u>2.3 Band Boundaries</u>	4
<u>3. Vendor Register</u>	4
<u>3.1 Classification Logic</u>	5
<u>4. Due Diligence Questionnaire</u>	6
<u>4.1 Information Security Policy Maturity</u>	6
<u>4.2 Access Control Practices</u>	6
<u>4.3 Incident Response Capability</u>	6
<u>4.4 Data Handling and Retention Practices</u>	6
<u>4.5 Subcontractor (Fourth-Party) Management</u>	7
<u>4.6 Audit and Certification Status</u>	7
<u>4.7 DPDP 2023 Compliance Posture (for vendors touching Indian personal data)</u>	7
<u>5. Worked Risk Assessments</u>	7
<u>5.1 Aegis Cloud Systems Pvt. Ltd. [CRITICAL TIER]</u>	8
<u>5.2 Aster Payment Gateway Solutions [CRITICAL TIER]</u>	8
<u>6. Fourth-Party Concentration Register</u>	10
<u>7. Monitoring Framework by Tier</u>	11
<u>8. Contractual Security Requirements</u>	12
<u>9. DPDP 2023 Overlay</u>	12
<u>9.1 When a DPA Is Mandatory</u>	12
<u>9.2 Minimum Contents of the DPA</u>	13
<u>9.3 Current Gap</u>	13
<u>9.4 Enforcement Timeline Note</u>	13
<u>10. Governance & RACI</u>	13

1. Risk Appetite & Tolerance Statement

This statement is issued because a risk score is only meaningful against a stated tolerance. Everything scored in Section 4 is scored against the appetite defined here — not against an implicit, undocumented sense of what is acceptable.

1.1 Statement

PaySafe India's third-party risk appetite is asymmetric by design: it tolerates a materially higher residual score in vendors whose failure degrades a control than in vendors whose failure stops transaction processing, because impact — not likelihood — is the harder variable to remediate after the fact. PaySafe India will not enter into, renew, or continue a Critical-tier vendor relationship carrying a Critical-band residual score (16–25) under any circumstance, regardless of commercial pressure to do so, and will not accept a High-band score (11–15) without a named, dated mitigation owner.

1.2 Appetite by Band and Required Sign-Off

Band	Score Range	PaySafe India Risk Appetite Position
Low	1–5	Within appetite. Accepted at TPR Manager discretion; logged, not escalated.
Medium	6–10	Within appetite subject to standard mitigating controls being in place and documented. TPR Manager accepts; Head of Compliance informed at next quarterly cycle.
High	11–15	Outside standing appetite. Requires a documented mitigation plan with a fixed closure date, and joint sign-off by CISO and Head of Compliance before the vendor relationship may commence or continue. Re-reviewed every quarter until the residual score drops to Medium or lower.
Critical	16–25	Unacceptable. The relationship may not commence, or must be suspended if already active, unless a compensating control reduces likelihood or impact enough to re-score into the High band or lower, with that compensating control verified — not merely committed to — before resumption. Requires Risk Committee escalation, not just CISO/Head of Compliance.

2. Risk Assessment Methodology

A risk score is only meaningful against a fixed, pre-defined scale, applied uniformly to every vendor in this register. Computing likelihood and impact inside individual worked examples, without a governing matrix stated once and referenced everywhere, invites internal inconsistency — the same score arrived at by different reasoning, or the same band labelled differently across vendors. The matrix below is defined once, applies uniformly to every vendor in this register, and is referenced — not restated — in every worked assessment that follows.

2.1 Scale Definitions

Likelihood and Impact are each scored 1–5 by a qualitative anchor, following the ISO 31000 / ISO 27005 convention this framework adopts:

- Likelihood: 1 Rare, 2 Unlikely, 3 Possible, 4 Likely, 5 Almost Certain — anchored to the vendor's demonstrated control maturity and any disclosed gap, not to a generic industry base rate.

Illustrative frequency anchors — used to keep two analysts consistent on the same vendor:

- 1 Rare: No comparable incident in the vendor's disclosed history within the last 3 years, and no structural reason to expect one (single-tenant architecture, no known subcontractor gap).

- 2 Unlikely: No incident at this vendor specifically, but a comparable incident has occurred elsewhere in its peer group within 3 years, or a minor, contained control gap is disclosed.
- 3 Possible: A specific, named, unremediated control gap is disclosed at the time of assessment (e.g., an unverified fourth-party flow-down, an ambiguous notification trigger) — the gap makes the event plausible within the current review cycle, not theoretical.
- 4 Likely: A comparable incident has occurred at this vendor within the last 24 months, or multiple unremediated control gaps compound.
- 5 Almost Certain: An incident is already underway, or a critical control is confirmed absent with no compensating control at the time of assessment.

Impact: 1 Negligible, 2 Minor, 3 Moderate, 4 Major, 5 Severe — anchored to the consequence for PaySafe India specifically (transaction-processing continuity, regulatory reportability, customer data exposure), not to the vendor's own impact framing.

2.2 The Matrix

Score = Likelihood × Impact. The matrix is fixed; only the two input scores are judgment calls, and both must be justified in prose in the worked assessment, not just asserted as a number.

Likelihood ↓ / Impact →	1	2	3	4	5
5 – Almost Certain	5	10	15	20	25
4 – Likely	4	8	12	16	20
3 – Possible	3	6	9	12	15
2 – Unlikely	2	4	6	8	10
1 – Rare	1	2	3	4	5

2.3 Band Boundaries

Band	Score Range	Definition
Low	1–5	Immaterial residual risk. No action required beyond routine monitoring at the assigned tier cadence.
Medium	6–10	Manageable residual risk. Standard mitigating controls and monitoring are sufficient; no incremental escalation required.
High	11–15	Material residual risk requiring a documented mitigation plan, a fixed closure date, and named sign-off (Section 1.2).
Critical	16–25	Unacceptable residual risk. Relationship cannot commence or continue without a verified compensating control and Risk Committee sign-off (Section 1.2).

There is no hybrid or boundary label. A score of 15 is High, full stop — the same score cannot be reported as High for one vendor and "High/Critical" for another. If a specific finding sits at a band's upper edge and the assessor believes it warrants closer monitoring than the band default, that judgment is stated explicitly in the mitigating-controls narrative, not encoded as an invented compound band.

3. Vendor Register

The register below covers the eight active third-party relationships that PaySafe India considers within scope for structured risk management — chosen because, between them, they touch every category the platform

depends on: infrastructure, payment execution, identity verification, fraud control, security operations, and outbound communication. Vendors that receive no PaySafe India data and have no system access (for example, our office facilities contractor) sit outside this register; they are managed under general procurement terms, not TPRM.

3.1 Classification Logic

Criticality is not assigned by gut feel. It is derived from two axes and then sanity-checked against a single practical question: if this vendor went dark tomorrow, does core payment processing stop?

- Data sensitivity — what the vendor can see or touch: No data, Non-sensitive data, Sensitive personal data, or Financial data (the last being the most sensitive, since it includes transaction and instrument details).
- Business dependency — whether the vendor sits on the critical path for authorizing or settling a transaction, or is a supporting function that degrades gracefully if it fails.

A vendor lands in the Critical tier when it holds Sensitive personal data or Financial data and its failure halts transaction processing outright — this is why the cloud host, the payment gateway, and the OTP gateway are all Critical: lose any one of them and UPI/card transactions stop, full stop. High tier covers vendors handling Sensitive personal data or Financial data where failure degrades a control (onboarding slows, fraud scoring reverts to static rules, security monitoring loses coverage) without stopping transaction flow immediately. Medium tier is Sensitive personal data with no transaction-path dependency at all. Low tier is Non-sensitive data with a function PaySafe India could route around within a business day.

Vendor	Service Provided	Data Access Level	Integration Type	Criticality
Aegis Cloud Systems Pvt. Ltd.	Core cloud infrastructure (IaaS/PaaS) hosting the UPI switch, card-processing environment, and core-banking interface	Sensitive personal data + Financial data	Direct DB access; API integration	Critical
Aster Payment Gateway Solutions	Payment gateway processing for card, UPI, and net-banking transactions	Financial data	API integration	Critical
Vahini Communication Services	SMS/OTP gateway for transaction authentication and customer notifications	Non-sensitive data (mobile numbers, transient OTP codes)	API integration	Critical
Nirmaan KYC Solutions	KYC/AML identity verification for customer onboarding and periodic re-KYC	Sensitive personal data	API integration; batch file transfer	High
Praxis Fraud Analytics	Real-time fraud detection and transaction risk scoring (SaaS)	Financial data	API integration; batch file transfer	High
Kavach Managed Security Services	Outsourced 24x7 SOC / managed detection and response (MDR) over production logs	Sensitive personal data (incidental, via logs)	API integration	High

Vendor	Service Provided	Data Access Level	Integration Type	Criticality
Sundial HR Payroll Outsourcing	Payroll processing and statutory filings for PaySafe India employees	Sensitive personal data (employee PII)	Batch file transfer	Medium
BhashaConnect Support Solutions	Multilingual customer support and chat-translation outsourcing	Non-sensitive data (support ticket text; limited PII)	API integration	Low

4. Due Diligence Questionnaire

This questionnaire is issued to every vendor at onboarding and re-issued on the cadence defined in Section 6. It is deliberately specific — generic questions produce generic, unfalsifiable answers, and a vendor risk analyst who accepts "yes, we have a security policy" without asking what's in it has not actually assessed anything.

4.1 Information Security Policy Maturity

- When was your information security policy last formally reviewed and approved, and by whom — is it a board-level artifact or an IT-department document that nobody outside IT has read?
- Do you maintain topic-specific policies (access control, cryptography, secure development) separate from a single umbrella policy, and can you share the table of contents?
- How is policy compliance measured — is there an internal audit function that tests these policies, or is compliance assumed based on the policy's existence?
- Describe your risk assessment methodology and how often it is refreshed for the specific relationship with PaySafe India.

4.2 Access Control Practices

- Is multi-factor authentication enforced for all remote and administrative access to systems that touch PaySafe India data, without exception for support or break-fix accounts?
- What is your process and target SLA for revoking access when an employee with access to PaySafe India systems or data leaves your organization or changes roles?
- Do you operate a formal privileged access management (PAM) solution, or do administrator credentials live in shared spreadsheets or password managers with standing access?
- How frequently are user access rights to PaySafe India data reviewed and recertified, and who signs off on that review?

4.3 Incident Response Capability

- What is your contractual and operational commitment for notifying PaySafe India of a security incident that may affect our data — and does that commitment distinguish between confirmed breaches and suspected/near-miss events?
- Walk us through your last actual security incident (not a tabletop exercise) — what happened, how long detection took, and what changed afterward.
- Do you maintain a tested incident response plan, and when was it last exercised — and can you produce evidence of that exercise rather than just the plan document?
- Who is our named point of contact during an incident, and is that contact available outside your normal business hours?

4.4 Data Handling and Retention Practices

- Where is PaySafe India data physically stored and processed — specifically, does any of it leave Indian jurisdiction at any point, including backups and disaster-recovery replicas?
- What is your data retention period for PaySafe India customer data, and what is the deletion mechanism at contract termination — is it cryptographic erasure, physical destruction, or something weaker?
- Is PaySafe India data encrypted at rest and in transit, and who holds the encryption keys — you, or a cloud provider you in turn depend on?
- Do you commingle PaySafe India's data with other clients' data in shared infrastructure, and if so, what logical separation controls are in place?

4.5 Subcontractor (Fourth-Party) Management

- Please provide a current, complete list of subcontractors who will have any access to PaySafe India data or systems, including cloud hosting providers you rely on.
- Do you require your own subcontractors to flow down the same security obligations we place on you, and can you show us evidence of that flow-down (not just an assertion)?
- Are we notified before you onboard a new subcontractor with access to our data, or only after the fact — and do we have any right to object?
- If a subcontractor of yours suffers a breach, what is your process for finding out and passing that notification to us within your committed SLA?

4.6 Audit and Certification Status

- Do you hold a current ISO/IEC 27001 certification, and can you provide the certificate along with the scope statement — not all certifications cover the systems relevant to us.
- If you process card data in any form, do you hold a current PCI DSS v4.0.1 attestation of compliance (AOC), and at what SAQ level or Report on Compliance tier — and if your AOC is still issued against the retired v3.2.1 or transitional v4.0 baseline, what is your committed date to complete the v4.0.1 ROC/AOC cycle?
- Do you undergo an annual SOC 2 Type II audit, and will you share the full report — with exceptions and management responses, not just the auditor's opinion letter?
- Have any of your certifications lapsed, been suspended, or been issued with qualified findings in the last 24 months?

4.7 DPDP 2023 Compliance Posture (for vendors touching Indian personal data)

- Do you have a designated process for handling data principal rights requests (access, correction, erasure) that are routed to you through PaySafe India as Data Fiduciary?
- What is your committed breach-notification timeline to PaySafe India, and is it fast enough for us to meet our own obligations to the Data Protection Board of India?
- Can you confirm in writing that you will process PaySafe India customer data only for the purposes specified in our agreement, with no secondary use for your own analytics, model training, or marketing?
- Are you prepared to execute a Data Processing Agreement that explicitly designates PaySafe India as Data Fiduciary and your organization as Data Processor under the DPDP Act, 2023?

5. Worked Risk Assessments

The two vendors below — Aegis Cloud Systems and Aster Payment Gateway Solutions — are PaySafe India's highest-criticality relationships, and both would stop transaction processing outright if they failed. Each includes a realistic self-reported DDQ response with at least one honest gap, and a risk rating computed against the fixed matrix in Section 2 — not rounded to fit a preferred narrative.

5.1 Aegis Cloud Systems Pvt. Ltd. [CRITICAL TIER]

Core cloud infrastructure (IaaS/PaaS) hosting the UPI switch, card-processing environment, and core-banking interface.

5.1.1 Vendor Self-Reported DDQ Response (Summarized)

Aegis reports ISO/IEC 27001:2022 certification covering its Mumbai and Pune data centers, with the certificate and scope statement provided on request. Access to management consoles is gated by MFA and a PAM solution, and access reviews run quarterly. Encryption at rest uses customer-managed keys for dedicated-tenancy customers, which PaySafe India's contract specifies. Their incident notification commitment is 4 hours for confirmed breaches. The gap: Aegis discloses that its DDoS-mitigation and network-monitoring function is subcontracted to a third-party provider, and while they "expect" that provider to meet equivalent security standards, they were unable to produce a signed security flow-down agreement with that subcontractor at the time of this assessment — it is described as "in legal review, expected to close next quarter."

5.1.2 Risk Assessment

Factor	Rating
Likelihood	Possible (3/5). Aegis's own controls are mature and independently certified; the residual risk sits specifically in the unverified fourth-party DDoS/monitoring subcontractor, where PaySafe India currently has no visibility into that subcontractor's actual security posture.
Impact	Severe (5/5). Aegis hosts the UPI switch and core-banking interface — a sustained outage or compromise here stops transaction processing across every product line, not just one.
Resulting Rating	$3 \times 5 = 15$ — High band (Section 2.3). The rating is driven by impact rather than likelihood: even a low-probability failure at this vendor is intolerable given what it hosts. Per Section 1.2, a High-band score requires a mitigation plan with a fixed closure date and joint CISO/Head of Compliance sign-off — see mitigating controls below, which supply that closure date.

5.1.3 Mitigating Controls / Contract Clauses

- Contract requires Aegis to complete the subcontractor security flow-down agreement within 60 days, with a right for PaySafe India to request evidence directly.
- Right-to-audit clause extended explicitly to cover fourth parties handling PaySafe India workloads, not just Aegis itself.
- Contractual requirement for architectural network segmentation so a compromise of the DDoS/monitoring subcontractor cannot pivot into the hosting environment.
- Quarterly review of Aegis's SOC 2 Type II report (in addition to the annual ISO 27001 surveillance audit) specifically scoped to monitor subcontractor management controls.

5.2 Aster Payment Gateway Solutions [CRITICAL TIER]

Payment gateway processing for card, UPI, and net-banking transactions.

5.2.1 Vendor Self-Reported DDQ Response (Summarized)

Aster holds PCI DSS v4.0.1 Level 1 Service Provider attestation (ROC/AOC issued against the current template) and a current SOC 2 Type II report, both shared in full including the exceptions log. MFA is enforced for all administrative access without exception, and deprovisioning runs through an automated HR-triggered workflow with a 4-hour SLA — noticeably tighter than PaySafe India's own internal SLA, which is

itself worth noting. Data retention for transaction logs is 180 days, after which records are purged via a documented, auditable process. The gap: Aster's breach-notification commitment in its standard master services agreement is 48 hours, not the 72-hour DPDP threshold — on its face this looks fine, but Aster candidly noted during the DDQ interview that the 48-hour clock starts from "confirmed and scoped" incidents, not from initial detection, which in practice could push actual notification well past 48 hours from the moment the incident began.

Blending notification-delay likelihood against an impact statement written for a halted-operations event compresses two distinct risks with two distinct impacts into one number, and leaves a mitigation owner unable to tell which lever actually closes the score. This register instead carries the exposure as two separate risk-register lines, each with likelihood and impact describing the same named event, per ISO 27005 §8.2 / FAIR convention.

5.2.2 Risk 1 — Aster Suffers a Security Incident (Operational/Availability Risk)

Factor	Rating
Likelihood	Unlikely (2/5). Aster's certification posture (PCI DSS v4.0.1 Level 1, SOC 2 Type II, enforced MFA, automated 4-hour deprovisioning) indicates low base-rate likelihood of an incident occurring at Aster itself.
Impact	Severe (5/5). Aster processes every card, UPI, and net-banking transaction — a gateway failure or breach halts revenue-generating operations immediately and is a certain RBI-reportable event.
Resulting Rating	$2 \times 5 = 10$ — Medium band (Section 2.3). Per Section 1.2, Medium-band risk is accepted by the TPR Manager on the strength of existing certifications and the Section 7 monitoring cadence; no incremental mitigation is required beyond what is already contracted.

5.2.3 Risk 2 — Delayed Breach Notification to PaySafe India (Compliance/Regulatory Risk)

Factor	Rating
Likelihood	Possible (3/5). Aster's notification clock starts from "confirmed and scoped," not initial detection — if Risk 1 materializes, there is a realistic chance PaySafe India is not notified within its own DPDP-driven timelines.
Impact	Major (4/5), not Severe. The consequence here is PaySafe India's own regulatory exposure to the Data Protection Board of India (Section 9) and the compliance/reputational cost of a late notification — not halted transaction processing. Halted operations is the consequence of Risk 1; it does not recur as the consequence of this risk.
Resulting Rating	$3 \times 4 = 12$ — High band (Section 2.3). Per Section 1.2, this requires a mitigation plan with a fixed closure date and joint CISO/Head of Compliance sign-off.

5.2.4 Mitigating Controls / Contract Clauses

The four controls below close Risk 2. Risk 1 carries no incremental mitigation beyond the certifications already in place.

- Renegotiate the breach-notification clause at next renewal to start the clock from initial detection or reasonable suspicion, not from "confirmed and scoped," with a hard 24-hour interim notification for suspected incidents and full detail within 72 hours.
- Require Aster to name a 24x7 incident contact with contractual escalation to PaySafe India's Head of IT Security.

- Right to conduct a joint incident-response tabletop exercise annually.
- Financial penalty clause tied to notification-SLA breaches, since the current gap has no consequence attached to it today.

6. Fourth-Party Concentration Register

A subcontractor disclosed inside a single vendor's worked assessment is the wrong place for that exposure to live: fourth-party exposure is a population-level risk, not a single-vendor footnote, and a vendor going dark at the fourth-party layer can affect PaySafe India through more than one primary vendor at once if those vendors share a common subcontractor. This register makes fourth-party visibility a standing artifact, tracked for all eight vendors, updated at every DDQ re-issue (Section 4.5) and every tier-appropriate re-assessment (Section 7).

Primary Vendor	Disclosed Subcontractor(s)	Flow-Down Agreement Status	Concentration Flag
Aegis Cloud Systems	DDoS-mitigation / network-monitoring provider (named to PaySafe India, not disclosed in this document per NDA scope)	Not executed — in legal review, target close within 60 days of contract per Section 5.1.3	Single point of exposure for all UPI/card transaction infrastructure if this subcontractor fails; highest-priority fourth party in the register
Aster Payment Gateway Solutions	Not yet disclosed	Pending — DDQ Section 4.5 response outstanding	Unconfirmed. Aster's own hosting dependency has not been established; open item for next DDQ cycle
Vahini Communication Services	Not yet disclosed	Pending — DDQ Section 4.5 response outstanding	Unconfirmed. SMS/OTP delivery frequently depends on telecom aggregator subcontractors; specific aggregator not yet named
Nirmaan KYC Solutions	Not yet disclosed	Pending — DDQ Section 4.5 response outstanding	Unconfirmed
Praxis Fraud Analytics	Not yet disclosed	Pending — DDQ Section 4.5 response outstanding	Unconfirmed
Kavach Managed Security Services	Not yet disclosed	Pending — DDQ Section 4.5 response outstanding	Unconfirmed. A shared SOC tooling vendor between Kavach and any other party in this register would itself be a concentration finding once disclosed
Sundial HR Payroll Outsourcing	Not yet disclosed	Pending — DDQ Section 4.5 response outstanding	Low priority given Medium tier, but not

Primary Vendor	Disclosed Subcontractor(s)	Flow-Down Agreement Status	Concentration Flag
			exempt from disclosure
BhashaConnect Support Solutions	Not yet disclosed	Pending — DDQ Section 4.5 response outstanding	Low priority given Low tier, but not exempt from disclosure

Honest status note: only Aegis's fourth-party exposure is currently substantiated because only Aegis's DDQ response disclosed it in detail. The other seven rows are placeholders, not findings — they exist so the register cannot silently omit a vendor, and so that "not yet disclosed" is visible as an open item rather than defaulting to an assumed clean bill. Section 4.5 questions are now asked of every vendor at every DDQ cycle specifically to close these rows. A vendor that cannot answer Section 4.5 within one re-issue cycle is itself a finding, escalated per Section 1.2.

Standing concentration exposure to watch across the population: multiple vendors in this register plausibly run on the same two or three hyperscale cloud providers. If confirmed, a single hyperscaler outage could degrade Aegis, and independently degrade a second vendor's own infrastructure, simultaneously — a correlated failure the current per-vendor tiering does not capture on its own. This is flagged as an open methodology item, not yet quantified, pending subcontractor disclosure across the register.

7. Monitoring Framework by Tier

Vendor risk does not stay fixed at the tier assigned during onboarding. A vendor's control environment can degrade quietly — a certificate lapses, a subcontractor changes, a key person leaves — and the only way to catch that before it becomes an incident is a monitoring cadence that scales with how much damage that vendor could do if something went wrong.

Tier	Review Cadence	Full Re-Assessment	Monitoring Activities per Cycle
Critical	Quarterly review	Annual full re-assessment	DDQ re-send at full re-assessment; review of current SOC 2 Type II report or ISO 27001 certificate at every quarterly cycle; incident notification log review; exercise of right-to-audit clause at least once per year, or on trigger (e.g., a missed SLA or a subcontractor change).
High	Semi-annual review	Annual full re-assessment	DDQ re-send at full re-assessment; certificate/report currency check each semi-annual cycle; incident log review; right-to-audit exercised on a risk-triggered basis rather than routinely.
Medium	Annual review	Annual full re-assessment (combined with review)	DDQ re-send annually; certificate currency confirmed by attestation letter rather than full document review; incident log spot-check.
Low	Annual review	Annual full re-assessment (combined with review)	DDQ re-send annually; self-attestation of continued compliance accepted in lieu of document review, unless a trigger event (breach, ownership change, service expansion) escalates the vendor to a higher tier mid-cycle.

Any vendor can be pulled forward for an out-of-cycle review regardless of tier if a trigger event occurs: a reported breach anywhere in the vendor's environment (not just ours), a lapsed or downgraded certification, a change of ownership or outsourcing arrangement, or a material expansion in the data or systems the vendor touches. Cadence is a floor, not a ceiling.

8. Contractual Security Requirements

The five clauses below are non-negotiable baseline requirements in every vendor contract, regardless of criticality tier — even the Low-tier translation vendor signs these. Tiering changes monitoring intensity; it does not change what a contract is required to contain.

Clause	Minimum Requirement
Data Protection / Confidentiality Obligations	Vendor commits in writing to process PaySafe India data only for the specified purpose, applies confidentiality obligations surviving contract termination, and discloses any data location outside India.
Incident Notification	Vendor notifies PaySafe India within 72 hours of becoming aware of any actual or suspected incident affecting PaySafe India data or systems; the clock starts at awareness, not at confirmation, and an interim notification is required even before the incident is fully scoped.
Right to Audit	PaySafe India, or an independent auditor acting on its behalf, may audit the vendor's controls relevant to this relationship, with reasonable notice, at least annually for Critical/High-tier vendors and on a risk-triggered basis otherwise.
Subcontractor Approval	Vendor must obtain PaySafe India's prior written approval before onward disclosure of PaySafe India data to any subcontractor, and must flow down equivalent security obligations to that subcontractor.
Data Deletion / Return on Termination	On contract termination, vendor must return or verifiably delete all PaySafe India data within a defined window (30 days unless a regulatory retention obligation applies), with written certification of deletion provided to PaySafe India.

9. DPDP 2023 Overlay

This section is not a footnote bolted onto a generic vendor-risk template — it reflects a specific legal obligation. Under the Digital Personal Data Protection Act, 2023, PaySafe India acts as Data Fiduciary for its customers' personal data. Any vendor that processes that data on PaySafe India's behalf — Nirmaan KYC Solutions, Vahini Communication Services, Praxis Fraud Analytics, and Aegis Cloud Systems, among others in this register — is a Data Processor, and the relationship between Data Fiduciary and Data Processor must be governed by a Data Processing Agreement (DPA). A commercial services agreement with a confidentiality clause is not a substitute for this, and PaySafe India does not treat it as one.

9.1 When a DPA Is Mandatory

A DPA is required wherever a vendor processes personal data of Indian data principals on PaySafe India's behalf — this includes vendors with direct access to customer PII (KYC documents, mobile numbers, transaction records) as well as vendors with incidental access through logs or support tooling (for example, Kavach's SOC access to production logs that may contain customer identifiers). "We don't primarily process personal data" is not an exemption; the test is whether personal data is processed at all, not whether it is the vendor's main business.

9.2 Minimum Contents of the DPA

- **Purpose Limitation** — the vendor may use the data only for the contracted purpose and nothing adjacent; a KYC vendor cannot repurpose verification data for its own model training or a secondary product, even anonymized, without a separate, explicit basis.
- **Data Principal Rights Mechanism** — a defined process for handling access, correction, and erasure requests that data principals route through PaySafe India as Data Fiduciary; the vendor commits to a response SLA that lets PaySafe India meet its own obligations to the individual.
- **Breach Notification Timelines and Responsibilities** — the vendor notifies PaySafe India promptly enough that PaySafe India can meet its own reporting obligations to the Data Protection Board of India; responsibility for notifying affected data principals stays with PaySafe India as Data Fiduciary, but the vendor must supply the facts needed to do that notification accurately and on time.
- **Sub-Processor Flow-Down** — any DPA obligation imposed on the primary vendor extends contractually to that vendor's own sub-processors, closing the fourth-party gap tracked in Section 6.
- **Data Localization and Cross-Border Transfer Disclosure** — where any processing occurs outside India, the DPA must disclose this explicitly; the DPDP Act permits cross-border transfer except to countries restricted by the Central Government, but PaySafe India's own risk appetite requires disclosure regardless of jurisdiction.

9.3 Current Gap

The Sundial HR Payroll relationship and the BhashaConnect support relationship were both onboarded under "data exchange" contract templates that predate this framework and do not contain an executed DPA, despite both processing personal data (employee PII and customer support ticket content with incidental PII, respectively). Both are scheduled for DPA execution within the current renewal cycle, tracked as an action item owned by the Third-Party Risk Manager alongside Legal.

9.4 Enforcement Timeline Note

The 72-hour breach-notification obligation referenced throughout this framework (Sections 5.2, 8, 9.2) is drawn from the DPDP Rules, 2025. Breach-notification provisions are on a phased enforcement timeline and are expected to be fully enforceable by approximately May 2027, roughly 18 months after the November 2025 notification. This framework treats the 72-hour standard as binding now, ahead of full enforcement, because contract renegotiation lead times (Section 5.2.4) make waiting until the compliance deadline operationally unworkable — not because the obligation is already in force today.

10. Governance & RACI

Naming the roles that own this framework (CISO, Head of Compliance, TPR Manager) is not the same as assigning decision rights. "Who is accountable for approving a vendor at High-tier residual risk" and "who is merely informed of it" are different questions, and this section answers both.

Activity	Responsible	Accountable	Consulted	Informed
Vendor tiering & classification (Section 3.1)	TPR Manager	Head of Compliance	CISO, Business Owner	—
DDQ issuance & review (Section 4)	TPR Manager	TPR Manager	—	Legal (for DPA-related items)
Risk scoring against the matrix (Section 2)	TPR Manager	CISO	Head of Compliance	—
Residual risk acceptance — Low/Medium band	TPR Manager	TPR Manager	—	Head of Compliance (informed)

Activity	Responsible	Accountable	Consulted	Informed
Residual risk acceptance — High band	CISO & Head of Compliance (joint)	CISO	TPR Manager, Business Owner	Risk Committee (informed)
Residual risk acceptance — Critical band	CISO	Risk Committee	Head of Compliance, TPR Manager, Legal	Board Audit Committee (informed)
Contract clause negotiation (Section 8)	Legal	Legal	TPR Manager, CISO	Business Owner
DPA execution (Section 9)	Legal	Legal	TPR Manager	Head of Compliance
Ongoing monitoring execution (Section 7)	TPR Manager	TPR Manager	—	CISO (quarterly, Critical tier only)
Out-of-cycle trigger review	TPR Manager	CISO	Head of Compliance	Business Owner
Vendor offboarding & data deletion verification	TPR Manager	TPR Manager	Legal	CISO (informed)

Reading note: "Responsible" performs the work; "Accountable" owns the outcome and is the one whose sign-off actually gates the decision — these are frequently, and deliberately, not the same person once risk crosses into the High band. This distinction is what Section 1.2's appetite table depends on to be enforceable rather than aspirational. The Critical-band row is deliberately the only row where Accountable sits above the CISO — the CISO prepares and is Responsible for the case, but the Risk Committee is Accountable and holds the actual gate, matching Section 1.2's requirement that Critical band "requires Risk Committee escalation, not just CISO/Head of Compliance."

Index

B

Breach Notification	9
---------------------------	---

D

Data Fiduciary	7
Data Processing Agreement (DPA)	12
Data Processor	12
Data Protection Board of India	7
DPDP Act, 2023	7
Due Diligence Questionnaire (DDQ)	6

F

FAIR Model (Factor Analysis of Information Risk)	9
Fourth-Party Concentration Register	10

I

ISO 31000	3
ISO/IEC 27001:2022	8
ISO/IEC 27005	3

K

KYC (Know Your Customer)	1
--------------------------------	---

M

MFA (Multi-Factor Authentication)	9
---	---

P

PCI DSS v4.0.1	9
----------------------	---

R

RACI (Responsible, Accountable, Consulted, Informed)	13
RBI (Reserve Bank of India)	9
Risk Appetite Statement	3
Risk Committee	14

S

SOC 2 Type II	7
---------------------	---

— End of Framework —